

NUST Cyber Security Team Lab Guide

September 5, 2025

Introduction

This lab is all about understanding the major Active Directory (AD) vulnerabilities from 2007 to 2019. Each entry highlights the vulnerability, its impact on AD or Windows domains, how attackers could exploit it, and the official mitigation or patch guidance. The goal is to help students learn how AD security has evolved over the years, and how proactive patching and hardening can prevent domain compromise. Additional vulnerabilities affecting non-AD systems (e.g., web applications, VPNs) are included to provide a broader understanding of system security. For further research, visit the National Vulnerability Database (<https://nvd.nist.gov/vuln/search>).

Vulnerabilities (2007–2019)

Year	Vulnerability	Description & Fix	Reference Link
2007	MS07-029	DNS RPC RCE in Domain Controllers running DNS. Allows attackers to execute code remotely, compromising AD infrastructure. <i>Fix:</i> Apply MS07-029; audit/retire legacy OS.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2007/ms07-029
2008	MS08-067	Server Service RCE (wormable, e.g., Conficker). Provides foothold for domain takeover via malicious network packets. <i>Fix:</i> Apply MS08-067; block SMB from untrusted sources; retire old OS.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2008/ms08-067
2009	MS09-050	SMBv2 RCE in Windows systems. Exploitable to gain unauthorized access in AD environments. <i>Fix:</i> Apply MS09-050; restrict SMB; segment networks.	https://www.tenable.com/plugins/nessus/40571
2010	MS10-061	Print Spooler RCE (Stuxnet technique). Allows code execution on AD systems with print services. <i>Fix:</i> Apply MS10-061; disable Spooler on DCs; block remote printing.	https://nvd.nist.gov/vuln/detail/CVE-2010-2729

Year	Vulnerability	Description & Fix	Reference Link
2012	MS12-020	RDP RCE in Windows systems. Exploitable to compromise AD-connected machines via remote desktop. <i>Fix:</i> Patch MS12-020; enable NLA; restrict RDP exposure.	https://nvd.nist.gov/vuln/detail/CVE-2012-0002
2012	CVE-2012-0158	ActiveX buffer overflow in Microsoft Office 2007 SP3, 2010 SP2, 2013 SP1. Allows RCE via crafted Office files, targeting AD user accounts. <i>Fix:</i> Apply Microsoft security updates for affected Office versions.	https://nvd.nist.gov/vuln/detail/CVE-2012-0158
2013	MS13-098	Signed PE handling RCE in Windows. Exploitable to execute malicious code in AD environments. <i>Fix:</i> Patch MS13-098.	https://nvd.nist.gov/vuln/detail/CVE-2013-3900
2014	MS14-025	Group Policy Preferences (GPP) password disclosure. Exposes credentials in AD Sysvol, enabling privilege escalation. <i>Fix:</i> Patch; remove GPP cpassword items; rotate credentials.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2014/ms14-025
2014	MS14-068	Kerberos PAC Forgery. Allows attackers to forge Kerberos tickets, escalating to domain admin. <i>Fix:</i> Patch all DCs; reset KRBTGT twice if compromised.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2014/ms14-068
2014	KB2871997	Credential protection hardening. Mitigates credential theft in AD by addressing WDigest vulnerabilities. <i>Fix:</i> Deploy KB2871997; set UseLogonCredential=0; enable LSA protection.	https://support.microsoft.com/help/2871997
2015	MS15-011/ MS15-014	Group Policy / UNC Hardening. Prevents unauthenticated access to AD resources via UNC paths. <i>Fix:</i> Patch; enforce UNC hardening; sign SMB; restrict NTLM.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2015/ms15-011
2015	CVE-2015-1641	RCE in Microsoft Office 2007 SP3, 2010 SP2, 2013 SP1, and Word for Mac 2011 via crafted documents, exploitable in AD environments. <i>Fix:</i> Update affected Microsoft products with security patches.	https://nvd.nist.gov/vuln/detail/CVE-2015-1641
2016	MS16-072	Group Policy privilege fix. Corrects GPO security filtering issues that could allow privilege escalation in AD. <i>Fix:</i> Patch; fix GPO security filtering/permissions.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2016/ms16-072

Year	Vulnerability	Description & Fix	Reference Link
2017	MS17-010	SMBv1 RCE (EternalBlue, WannaCry/NotPetya) in Windows Vista SP2 through Windows 10, Server 2008-2016. Critical for AD domain controllers. <i>Fix:</i> Patch MS17-010; remove SMBv1; segment networks.	https://learn.microsoft.com/en-us/security-updates/SecurityBulletins/2017/ms17-010
2017	CVE-2017-0199	RCE in Microsoft Office 2007 SP3, 2010 SP2, 2013 SP1, 2016, and WordPad via malicious RTF files, targeting AD users. <i>Fix:</i> Apply Microsoft security updates for Office and Windows.	https://nvd.nist.gov/vuln/detail/CVE-2017-0199
2017	CVE-2017-5638	RCE in Apache Struts 2.3.x before 2.3.32 and 2.5.x before 2.5.10.1 via malformed Content-Type header (Equifax breach). May affect AD-integrated web apps. <i>Fix:</i> Upgrade to Apache Struts 2.3.32 or 2.5.10.1 or later.	https://nvd.nist.gov/vuln/detail/CVE-2017-5638
2017	CVE-2017-8759	RCE in Microsoft .NET Framework 2.0 SP2, 3.5, 3.5.1, 4.5.2, 4.6, 4.6.1, 4.6.2, 4.7 via malicious documents, affecting AD environments. <i>Fix:</i> Apply Microsoft security updates for .NET Framework.	https://nvd.nist.gov/vuln/detail/CVE-2017-8759
2017	CVE-2017-8563	LDAP authentication hardening. Mitigates privilege escalation via weak LDAP configurations in AD. <i>Fix:</i> Apply KB4034879; enable LDAP signing & channel binding.	https://support.microsoft.com/help/4034879
2017	CVE-2017-11882	Memory corruption in Microsoft Office 2007 SP3, 2010 SP2, 2013 SP1, 2016, allowing RCE via crafted files, exploitable in AD. <i>Fix:</i> Apply Microsoft security updates; use Microsoft Defender to detect and patch.	https://nvd.nist.gov/vuln/detail/CVE-2017-11882
2018	CVE-2018-0886	CredSSP RCE in RDP (MITM/credential theft). Exploitable to steal AD credentials via compromised RDP sessions. <i>Fix:</i> Patch clients/servers; enforce CredSSP policy.	https://nvd.nist.gov/vuln/detail/CVE-2018-0886
2018	CVE-2018-4878	Use-after-free in Adobe Flash Player before 28.0.0.161, leading to RCE, potentially affecting AD-integrated systems. <i>Fix:</i> Update to Adobe Flash Player 28.0.0.161 or later; migrate to alternatives (Flash is end-of-life).	https://nvd.nist.gov/vuln/detail/CVE-2018-4878

Year	Vulnerability	Description & Fix	Reference Link
2018	CVE-2018-7600	RCE in Drupal 7.x before 7.58, 8.x before 8.3.9/8.4.6/8.5.1 via unsanitized requests (Drupalgeddon2). May affect AD-integrated CMS. <i>Fix:</i> Upgrade to the latest Drupal 7 or 8 core version.	https://nvd.nist.gov/vuln/detail/CVE-2018-7600
2018	CVE-2018-8581	PrivExchange (Exchange NTLM relay to AD). Allows attackers to escalate privileges via Exchange Server relay attacks. <i>Fix:</i> Patch Exchange; restrict NTLM/SMB; implement EPA.	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2018-8581
2018	CVE-2018-13379	Path traversal in Fortinet FortiOS 5.4.6-5.4.12, 5.6.3-5.6.7, 6.0.0-6.0.4, allowing unauthorized file access. May affect AD-connected VPNs. <i>Fix:</i> Upgrade to latest Fortinet FortiOS version; monitor for unusual files or tasks.	https://nvd.nist.gov/vuln/detail/CVE-2018-13379
2019	CVE-2019-0604	RCE in Microsoft SharePoint Server 2010 SP2, 2013 SP1, 2016, 2019, often integrated with AD for authentication. <i>Fix:</i> Apply Microsoft security updates for SharePoint.	https://nvd.nist.gov/vuln/detail/CVE-2019-0604
2019	CVE-2019-1040	NTLM MIC bypass/relay. Allows attackers to relay NTLM auth to gain unauthorized AD access. <i>Fix:</i> Patch; enforce SMB/LDAP signing; disable NTLM.	https://nvd.nist.gov/vuln/detail/CVE-2019-1040
2019	CVE-2019-11510	Arbitrary file disclosure in Pulse Secure Pulse Connect Secure 8.2 before 8.2R12.1, 8.3 before 8.3R7.1, 9.0 before 9.0R3.4 via directory traversal. May affect AD-connected VPNs. <i>Fix:</i> Upgrade to latest Pulse Secure version; detect directory traversal attempts.	https://nvd.nist.gov/vuln/detail/CVE-2019-11510
2019	CVE-2019-11580	RCE in Atlassian Crowd and Crowd Data Center 2.1.0 to 3.4.4 via pdkinstall plugin. May affect AD-integrated authentication systems. <i>Fix:</i> Download and install fixed software from Atlassian.	https://nvd.nist.gov/vuln/detail/CVE-2019-11580
2019	CVE-2019-1338	Additional NTLM tampering. Enables unauthorized access via NTLM manipulation in AD environments. <i>Fix:</i> Patch; enforce SMB/LDAP signing; prefer Kerberos; enable EPA.	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2019-1338

Year	Vulnerability	Description & Fix	Reference Link
2019	CVE-2019-19781	Directory traversal in Citrix ADC and Gateway 10.5, 11.1, 12.0, 12.1, 13.0, leading to RCE. May affect AD-connected VPNs. <i>Fix:</i> Apply Citrix patches; restrict VPN access to known IPs.	https://nvd.nist.gov/vuln/detail/CVE-2019-19781
2019	CVE-2019-3396	RCE in Atlassian Confluence Server and Data Center before 6.6.12, 6.7.0-6.12.3, 6.13.0-6.13.3, 6.14.0-6.14.2 via Widget Connector macro. May affect AD-integrated systems. <i>Fix:</i> Download and install fixed Confluence version.	https://nvd.nist.gov/vuln/detail/CVE-2019-3396

Generated on September 5, 2025. For additional vulnerabilities, search the NVD at <https://nvd.nist.gov/vuln/search>. This document is intended for educational purposes in controlled environments only.

Conclusion

Key Takeaways from AD Vulnerability Analysis (2007–2019)

Evolution of Attack Vectors: The vulnerability landscape shows a clear evolution from basic service exploits (MS07-029) to sophisticated authentication bypasses and supply chain attacks. Notable patterns include the progression from simple RCE vulnerabilities to complex privilege escalation techniques targeting AD-specific components like Kerberos and NTLM.

Critical AD-Specific Vulnerabilities: Several vulnerabilities stand out as particularly dangerous to Active Directory environments:

- MS14-068 (Kerberos PAC Forgery) – Allowed complete domain compromise through ticket forgery.
- MS14-025 (GPP Password Disclosure) – Exposed plaintext credentials in AD Sysvol.
- MS17-010 (EternalBlue) – Enabled wormable attacks across AD networks.
- CVE-2019-1040/1338 (NTLM Relay) – Facilitated lateral movement within AD domains.

Defense Strategy Recommendations:

- *Proactive Patching:* Implement systematic patch management with priority given to AD-related vulnerabilities.
- *Protocol Hardening:* Enforce SMB signing, LDAP signing, and channel binding to prevent relay attacks.
- *Legacy Protocol Removal:* Disable SMBv1, reduce NTLM usage in favor of Kerberos.
- *Network Segmentation:* Isolate domain controllers and limit lateral movement opportunities.
- *Credential Protection:* Implement LSA protection, disable WDigest, and regularly rotate service account passwords.

Emerging Threat Patterns: The later years (2017–2019) show increased targeting of third-party applications integrated with AD (VPNs, web applications, collaboration tools), highlighting the need for comprehensive security assessments beyond core AD infrastructure.

Compliance and Monitoring: Organizations should implement continuous monitoring for indicators of these historical attacks, as threat actors often reuse successful techniques against unpatched systems. Regular AD security assessments and penetration testing should specifically test for these known vulnerabilities.

Additional Resources

For Continued Learning

- NIST National Vulnerability Database: <https://nvd.nist.gov/vuln/search>
- Microsoft Security Response Center: <https://msrc.microsoft.com/update-guide>
- MITRE ATT&CK Framework: <https://attack.mitre.org>
- SANS Reading Room: <https://www.sans.org/reading-room>

Lab Exercises

Students should practice identifying these vulnerabilities in controlled environments, implement the recommended fixes, and understand how each vulnerability could be chained together for more complex attacks.